

Topic 1: Footprinting Tools – Conducting Competitive Intelligence (15 Marks)

1. Tool Selection for Information Gathering (8 Marks)

- **Domain Registration Details (WHOIS):** Queries regional internet registries to retrieve registrar information, domain ownership, creation/expiry dates, and contact details.

PDF

- **Employee Email Addresses (theHarvester / Hunter.io):** Scrapes search engines, PGP key servers, and data repositories to compile lists of public email addresses linked to the @abctechnologies.com domain.

PDF

- **Technology Stack (BuiltWith / Wappalyzer):** Analyzes server headers, client-side scripts, and web frameworks to identify the web server (e.g., Nginx, Apache), CMS, backend frameworks, and analytics tools used by the target.

PDF

- **Publicly Exposed Subdomains (Amass / Sublist3r / Shodan):** Uses passive OSINT techniques (DNS datasets, SSL/TLS certificates, search engine dorks) to map out subdomains without touching the company's network infrastructure directly.

PDF

2. Competitive Intelligence & Reconnaissance Analysis (7 Marks)

- **Mapping Organizational Hierarchy:** Uncovering employee email structures aids in understanding department setups and identifying key personnel (e.g., IT staff, C-level executives) for target profiling.

PDF

- **Identifying Infrastructure Vulnerabilities:** Knowing the specific web technology stack and versions allows security teams to identify outdated components, known CVEs, and potential soft spots in the target's perimeter.

PDF

- **Exposing Unlinked Assets:** Subdomain discovery exposes staging environments, legacy portals, or admin panels that might lack security controls, revealing potential entry points or ongoing development projects.

PDF

Topic 2: DNS Zone Transfers (15 Marks)

1. DNS Zone Transfer Verification (6 Marks) To test for an open DNS zone transfer (AXFR) on the target domain using standard command-line tools:

- **Using dig:**
 1. Find the authoritative Name Servers: `dig axfr @<Name_Server_IP> <targetdomain.com>`
 2. Perform the Zone Transfer: `dig axfr @ns1.targetdomain.com targetdomain.com`
- **Using nslookup:**

Plaintext

nslookup

> set type=ns

> targetdomain.com

> server <Name_Server_IP>

> ls -d targetdomain.com

If the command succeeds, the server returns the complete DNS database for the zone.

PDF

2. Practical Utility of Retrieved DNS Records (9 Marks)

- **Identifying Internal Hosts (A / AAAA Records):** Mapping specific hostname-to-IP pairings exposes host naming conventions, internal network structures, and active devices.

PDF

- **Mail Server Intelligence (MX Records):** Reveals primary and backup mail servers, pointing directly to potential targets for email filtering bypasses or mail-server-specific exploits.

PDF

- **Subdomain & Service Mapping (CNAME / SRV / TXT Records):** Discovers hidden web services, voice/SIP services, third-party integrations (e.g., SPF records showing SaaS usage), and internal administrative domains.

PDF

Topic 3: Introduction to Social Engineering – Attacks and Countermeasures (20 Marks)

1. Attack Identification (4 Marks)

- **Primary Attack: Phishing (Credential Harvesting).**

PDF

- **Key Indicators:** Urgency trigger ("urgent security update"), authority impersonation ("IT Department"), and redirection to an external URL to capture login details.

PDF

2. Employee Countermeasures Before Responding (8 Marks)

- **Sender & Domain Verification:** Inspect the full email header and sender address to verify it matches the internal corporate domain rather than a lookalike domain.

PDF

- **Link Inspection:** Hover over the provided link to view the actual destination URL; never click unverified links.
- **Out-of-Band Verification:** Contact the IT Helpdesk directly via a known, official channel (e.g., internal extension, verified chat channel) to confirm the request.
- **Report the Incident:** Utilize the organization's "Report Phishing" button or immediately notify the SOC/Security operations team.

3. Prevention Mechanisms against Credential Theft (8 Marks)

- **Validation Breaks the Attack Chain:** Verifying the request independently prevents users from submitting credentials to adversary-controlled servers.
- **Multi-Factor Authentication (MFA) Mitigations:** Even if a password is breached, robust MFA (FIDO2/Security Keys or app push notifications) prevents attackers from gaining unauthorized access.

- **Prompt Incident Response:** Reporting phishing emails enables IT to block the malicious domain at the email gateway and perimeter firewall, protecting other employees in real time.

Topic 1: Footprinting Tools – Conducting Competitive Intelligence (15 Marks)

Passive Reconnaissance & OSINT Expansion (8 Marks)

- **OSINT Search Engines (Shodan / Censys):** Scans internet-facing devices to index open ports, running services, web server certificates, and banner details without sending traffic to the target network.
- **Code Leakage Detection (GitGuardian / TruffleHog):** Continuously monitors public code hosting sites like GitHub and GitLab for accidentally committed hardcoded API keys, database connection strings, or cloud access tokens.
- **Metadata Extraction (FOCA / ExifTool):** Scrapes publicly downloadable documents (PDFs, Word docs, spreadsheets) from the company website to extract author usernames, local network folder paths, software versions, and printer names.
- **Historical Infrastructure (Wayback Machine / SecurityTrails):** Examines historical DNS modifications and archived web page versions to locate legacy servers, retired portals, or inadvertently exposed internal URL structures.

Competitive Intelligence Analysis (7 Marks)

- **Mapping Technical Maturity:** Assessing the company's tech stack shifts, third-party SaaS tools, and cloud provider usage exposes operational capabilities and technical dependencies.
- **Threat Surface Identification:** Pinpointing unpatched framework versions or exposed staging subdomains establishes target priority lists for authorized penetration testing.
- **Social Engineering Profiling:** Extracting organizational naming conventions and employee roles from public metadata enables targeted security awareness evaluations.

Topic 2: DNS Zone Transfers (15 Marks)

Additional Verification Commands & Syntax (6 Marks)

- **Using host Command:**

Step 1: Identify authoritative name servers

```
host -t ns targetdomain.com
```

Step 2: Attempt AXFR zone transfer

```
host -l targetdomain.com ns1.targetdomain.com
```

...

- **Using dnsrecon Automated Utility:**

Bash

```
dnsrecon -d targetdomain.com -t axfr
```

...

If the DNS server is misconfigured to allow unrestricted AXFR queries, the full zone file is dumped immediately.

Exploiting Zone File Records in Reconnaissance (9 Marks)

- **Host Mapping (A / AAAA Records):** Maps external IPs to hostnames, exposing internal naming conventions (e.g., db-prod-01.targetdomain.com), server roles, and IP subnets.
- **Mail & Routing Intelligence (MX / PTR Records):** Discloses email gateway providers and backup mail infrastructure, enabling direct targeting of secondary mail pathways.
- **Service Discovery (SRV / TXT Records):** Uncovers active directory domains, SIP endpoints, and authentication configs (e.g., SPF, DKIM, DMARC policies revealing third-party cloud integrations).

Topic 3: Introduction to Social Engineering – Attacks and Countermeasures (20 Marks)

Attack Vectors & Psychological Mechanisms (4 Marks)

- **Primary Classification: Spear Phishing & Credential Harvesting.**
- **Triggers:** Plays on urgency ("immediate account termination"), authority ("IT Department"), and compliance to bypass employee skepticism.

- **Secondary Threats:** Fake credential portals often drop malware payloads or attempt session hijacking via adversary-in-the-middle (AiTM) reverse proxies.

Actionable Employee Countermeasures (8 Marks)

- **Header Inspection:** Verify sender email headers to detect domain spoofing or mismatches between the From and Return-Path fields.
- **Link Validation:** Avoid clicking links directly; hover to inspect destination URLs or analyze suspicious links using isolated sandbox tools (e.g., VirusTotal).
- **Out-of-Band Verification:** Contact the internal IT helpdesk directly using known internal extensions or chat channels—never reply to the suspicious email.
- **SOC Reporting:** Trigger immediate incident response by reporting the email via embedded enterprise phishing reporting buttons.

Mitigation & Credential Theft Prevention (8 Marks)

- **Zero-Trust Access Control:** Restricts unauthorized authentication attempts based on device health, IP location, and network posture.
- **Hardware-Based MFA:** Deploying FIDO2/WebAuthn security tokens (e.g., YubiKeys) stops credential theft, as the authentication token is bound strictly to the legitimate domain domain[cite: 1].
- **Email Gateway Policies:** Enforce strict DMARC (p=reject), SPF, and DKIM enforcement alongside automated link-rewriting web proxies[cite: 1].